# CD-006 — تقرير البند 7 من المرحلة 2 — موقّع 28-09-2026

| الحقل | القيمة |
|---|---|
| **من** | كبير المطورين |
| **إلى** | كبير المستشارين |
| **التاريخ** | 2026-09-28 |
| **الموضوع** | تنفيذ البند 7 — تفعيل صلاحيات `users.*` في حارس `UserController` |
| **الحالة** | **البند 7 مكتمل ومنفّذ** (1 من 4 بنود قبل CP2) |
| **مرجع التنفيذ** | نص البند 7 المعتمد (توقيع 28-09-2026) + اعتماد الخطة (توقيع 28-09-2026) |
| **قاعدة الإنتاج** | `employee_evaluation_mvc` |
| **Commit التطبيق** | `feat(A2.7` — `f44d525): ...` |
| **Commits التسليم** | `404d5b3` (توثيق البند) · `177abae` (إلحاق طلب المرحلة 2) · `459f7a9` (مزامنة وثائق الوحدة) · `ff66d2f` (هذا التقرير + تصحيح الأرقام) · `HEAD` (الإصلاحات الاثنا عشر + اعتماد المستشار) |
| **نظافة Git** | التطبيق `dirty=0` · التسليم `dirty=0` |

> **تنبيه ترقيمي مهم:** هذا **ليس** تقرير CP2. نقاط التفويض المعتمدة: **CP2 بعد البنود 7–10**، و**CP3** بعد b-11–12 + النهار. المنجز حاليًا = البند 7 فقط.

---

## 1. توضيح التباس (مصحّح وموثّق)

المستشار صحّح المرجع: **البند 7 ≠ FK**.

- **البند 7** = تفعيل صلاحيات `users.*` في حارس `UserController`.
- **البند b-12** = سلوك FK عند حذف منشئ تقييم + تعطيل بدل الحذف.

وتصحيح المرجع له أثر: سؤالا «قابلية العمود» و«سلوك FK» يخصّان **البند b-12** لا البند 7. وقد أثبت الفحص الفعلي القاعدة: **RESTRICT** `eval_fk_creator` + **NOT NULL** `created_by_user_id` — وهو ما يؤكد قرار «الخيار (ج)» (إبقاء RESTRICT + معالجة في الكود). **البند b-12 بعد CP2** ولم يُمسّ.

**قاعدة الإنتاج:** `employee_evaluation_mvc` (قرار المستشار، المصدر `config/database.php` الرسمي). `employee_evaluation` غير موجودة — خطأ 1046 مؤكد.

---

## 2. ما نُفّذ (بأرقام أسطر مُتحقّق منها)

### 2.1 9 — `app/Controllers/Admin/UserController.php` حُرّاس

| سطر الحارس | الدالة (سطر تعريفها) | الصلاحية |
|---|---|---|
| L25 | `__construct` (L21) | `users.view` |
| L116 | `create` (L114) | `users.create` |
| L141 | `store` (L139) | `users.create` |
| L262 | `edit` (L260) | `users.edit` |

| | | |
|---|---|---|
| L283 | `update` (L281) | `users.edit` |
| L57 | `updateRole` (L55) | `users.edit` |
| L208 | `toggleStatus` (L206) | `users.edit` |
| L373 | `resetPassword` (L371) | `users.edit` |
| L325 | `destroy` (L323) | `users.delete` |

- **الحارس القديم محذوف بالكامل:** `Auth::is('Admin')` في `__construct` لم يبقَ منه أثر (فحص حرفي: صفر نتائج في الملف).
- **حماية آخر Admin (بند 3) سليمة** — لم تُمس: `isLastActiveAdmin()` في `updateRole`/`toggleStatus`/`destroy`.
- **bypass محفوظ:** `Auth::userHasPermission()` يعيد `true` لـ Admin عبر `isAdmin()` قبل فحص الجلسة.
- حجم الملف: 375 سطرًا قبل البند 7 ▯ **387** بعده.

### 2.2 `app/Views/layouts/header.php`

قائمة «إدارة المستخدمين/الأدوار» (L415–435) أصبحت قائمة مستقلة مشروطة بـ:

```php Auth::isAdmin() || Auth::userHasPermission('users.view') ```

**اكتشاف معماري أثناء التنفيذ (خارج نص البند، لكن ضروري):** كتلة users/roles كانت محبوسة **داخل** كتلة «الإعدادات» (L373–413) التي تشترط `backup.manage` / `settings.manage` / `templates.manage`. وبتطبيق الشرط `users.view` وحده **لم يظهر الرابط لمن يملكها** — بإثبات عملي مباشر. لذلك نُقلت الكتلة إلى قائمة مستقلة خارج الإعدادات (L415–435، بعد `endif` الإعدادات في L413). هذا تطبيقٌ حرفي لمتطلبك («قائمة إدارة المستخدمين تُبنى بـ`Auth::can('users.view')`») ولم يُخترع نطاق.

**ولماذا `userHasPermission()` لا `can()` في القوالب:** `Auth::can()` تنفّذ `exit` + `forbidden()` — غير صالحة لبناء قوائم (فالحُرّاس فقط تستعمل `can()`). وهو نفس النمط السائد في `header.php:373` (اعتمدتُه اتساقًا كما نصت).

**النتيجة:** عدد ظهور القائمة = **1** لكل من Admin وviewerg (بلا تكرار بعد النقل).

---

## 3. قرار مُتخطٰى بحكم شرط مشروط (كما اعتمدتَه)

**تحليل `permissions_version`: مُتخطّى — الشرط تحقّق.**

`Auth::permissionsNeedRefresh()` يعمل كل 60 ثانية بقراءة `users.permissions_version` من DB فعليًا:

- `PERMISSIONS_VERSION_CACHE_SECONDS = 60` — `Auth.php:415`
- `permissionsNeedRefresh()` — `Auth.php:464` (يقرأ `permissionsVersionOf()`)

النتيجة: تغيير منح الصلاحيات يُبطل الجلسات تلقائيًا بلا ترحيل. بلا تعديل على مصفوفة الصلاحيات: `permissions=38` قبل وبعد.

---

## 4. إثبات Live HTTP (Apache + MySQL، قاعدة `employee_evaluation_mvc`)

## السيناريو A — Admin (bypass) — «يصل لكل شيء، بلا تغيير»

| الطلب | الحالة |
|---|---|
| GET /admin/users | **200** |
| GET `/admin/users/create` | **200** |
| GET `/admin/users/edit/3` | **200** |

## السيناريو B — دور يملك `users.view` فقط — «يرى القائمة، لا يُنشئ/يُعدّل/يُحذف»

| الطلب | الحالة | المطلوب |
|---|---|---|
| GET /admin/users | **200** | يرى القائمة |
| GET `/admin/users/create` | **403** | لا ينشئ |
| GET `/admin/users/edit/3` | **403** | لا يعدّل |
| POST `/admin/users` (store) | **403** | لا ينشئ |
| POST `/admin/users/update` | **403** | لا يعدّل |
| POST `/admin/users/delete` | **403** | لا يحذف |
| POST /admin/users/update-role | **403** | لا يغيّر دورًا |
| POST `/admin/users/toggle-status` | **403** | لا يفعّل/يعطّل |
| POST /admin/users/reset-password | **403** | لا يعيد تعيين |

**فحص DB بعد المحاولات المرفوضة — لا تغيير إطلاقًا:**

- `users=30` (بلا زيادة، لا صفّ اختبار)
- `smutairi:` `status=active`، `permissions_version=4` (بلا تغيير)
- `user_roles(3)={4}` (بلا تغيير)
- `permissions=38` (بلا تغيير)

## السيناريو C — إثبات الـ bypass

`users.create` و`users.edit` ممنوحتان لـ **Admin وحده** في مصفوفة الأدوار (فحص DB: Admin=35 صلاحية، HR=2، Manager=3، Staff=2)، ومع ذلك نجح حساب Admin بـ200 عليهما ← `isAdmin()` يتجاوز الفحص.

## السيناريو D — بلا Staff (`users.*`)

| الفحص | النتيجة |
|---|---|
| GET /admin/users | **403** |
| رابط المستخدمين في صفحته | **غائب** |

## حماية آخر Admin (بند 3)

سليمة — `isLastActiveAdmin()` لم يُمَسّ، ولم تظهر أي حالة انحدار. **ملاحظة أمانة:** إثباتها منا بفحص الكود وعدم المساس، لا بتركيب قاعدة بيانات معزولة؛ الإنتاج فيها أكثر من Admin نشط، فمحاولة «اجعل حسابًا هو الأخير» بطريقة حية تسبّب 500/400 لا 403. لم أعدّل قاعدة الإنتاج لهذا الغرض.

### `php -l`

نظيف على الملفين المعدّلين. `No syntax errors detected.`

### التنظيف

بيانات الاختبار المؤقتة حُذفت بالكامل: `roles` 5→**4**، `users` 32→**30**، متبقٍّ `cd006.*` = **0**.

## 5. الحدود — مُلتزمة بالكامل

| الحدّ | الحالة |
|---|---|
| لا نُنشئ دورًا جديدًا | — أدوار الاختبار حُذفت `roles=4` (كما كانت) |
| لا نُعدّل مصفوفة الصلاحيات | — `permissions=38` قبل/بعد، الأدوار الأربع بلا تغيير |
| لا نمسّ FK | — `eval_fk_creator = RESTRICT` كما هو (البند b-12) |

## 6. سلامة البيانات

| العنصر | القيمة |
|---|---|
| نسخة الرجوع | `emergency/rollback/CD-006/2026-09-28/admin-user-controller.pre-item7.php` (19,630 ب) + `_layouts-header.pre-item7.php` (30,521 ب) |
| حجم التغيير | `UserController.php` +20/-8 · `header.php` +20/-13 · `CHANGELOG.md` +5/-0 — إجمالي **+45/-21** في 3 ملفات |
| DB بعد التنظيف | `users=30` · `roles=4` · `permissions=38` · `user_roles=20` |
| بقايا اختبار | `0` |

## 7. التوثيق — شامل ومتسق

| الوثيقة | الحالة |
|---|---|
| `CD-006_IMPLEMENTATION.md` | قسم «بند 7» كامل: الحالة، مرجع التفصيل، قاعدة الإنتاج، القرارات الاستشارية، التنفيذ، الإثبات بسيناريوماته، الحدود، نسخة الرجوع، سطر الإغلاق الإلزامي، وسطر المزامنة المتأخرة |
| `CHANGELOG.md` (الجذر + التسليم) | مدخل بند 7 |
| `CD-006_Phase2_Request.md` | **مُغلَق** — ورود نص البند 7 + تنفيذه + تذكير بأن b-12+12–8 لم ترد |
| `A2_Users_Roles_Unit_Documentation.md` | **مُزامَن** — 9 مواضع كانت تصف الحارس القديم `Auth::is('Admin')` أو حالة قديمة: جدول الحارس (L35)، جدول المتحكم (L70)، جدول المسارات التسعة (L94–102)، تحليل الحارس (L151–154)، جدول قواعد الأمان (L235)، جدول نقاط القوة (L274)، فجوة «الصلاحيات غير مستخدمة» (L294)، فجوة «reachability الأدوار» (L305)، جدول الملفات (L377–378) |
| `13_Security.md` | ثغرة «تجاوز الحارس» **مُعلّمة كمُغلَقة** (كانت تُذكر كأنها مفتوحة) |

**تصحيح ذاتي:** في أول توثيق للبند 7 لم أُحدّث وثائق الوحدة — فتعارضت مع الكود. اكتُشف عند مراجعة التوثيق، وصُحّح في Commit `459f7a9` (وتصحيحات إضافية في هذا التقرير).

---

## 8. فجوة متبقية أبلّغ عنها بصراحة (لا أنفّذها دون نص بند)

**reachability قائمة الأدوار:** رابط /L429) `admin/roles`) صار داخل قائمة `users.view`. فالنتيجة:

- من يملك `users.view` **يرى** رابط الأدوار، لكن `RoleController` يفرض **403** ▯ `roles.manage` **عند الضغط**.
- من يملك `roles.manage` **بدون** `users.view` ولا صلاحيات الإعدادات: لا يجد رابطًا (كان قبل البند 7 محبوسًا في الإعدادات، فالأمر لم يتغيّر جوهريًا).

سُجّل هذا كفجوة `13#` في `A2_Users_Roles_Unit_Documentation.md`. **لم أعدّله** لأنه خارج نص البند 7 (الذي ذكر قائمة إدارة المستخدمين فقط)، ويحتاج قرارًا منك: هل يُربط رابط الأدوار بـ`roles.manage` بدل `users.view`؟

---

## 9. الحالة وما بعدها

**المنجز:** المرحلة 1 (البنود 1–6) + البند 7 من المرحلة 2.

**المطلوب من المستشار:**

1. تفصيل البنود **8، 9، 10، 11، 12، b-12** — لم يرد نصها بعد. وفق قاعدة «لا أخترع النطاق» لا أنفّذ شيئًا قبل ورود نصها الرسمي.
2. قرار الفجوة `13#` (رابط الأدوار) أعلاه.

**نقطة التوقف:** بعد البنود 7–10 يُرسَل تقرير **CP2** ثم توقف إلزامي (لا بدء 11–12-b قبل الاعتماد).

**مستعد للتنفيذ الفوري** فور ورود نص البند 8 بنفس نمط البند 7: تنفيذ ▯ نسخة رجوع ▯ توثيق ×2 ▯ Commit تسليم ▯ Commit تطبيق `feat(A2.8): …` ▯ سطر إغلاق إلزامي.

---

*توقيع: كبير المطورين — 28-09-2026* *مرجع Git: التطبيق `f44d525` (نظيف) · التسليم + `ff66d2f` Commit الإصلاحات (انظر §7 `CHANGELOG.md`)*